MailSentra

Multi-Modal Email Threat Detection & Defense Platform

Full System Document

System Overview

Our system is a lightweight detection, defense and also give awareness for end users by analyzing AI scams. So final product we built is a web extension for the Thunderbird email client. Means, it works on the thunderbird email client like a web extension.

Research Problem

In the current world there are many tools and awareness session for establsihed to prevent users from having AI scams. But still the world has question “Even though there are many tools available in the world, but why we can not stop even 50% of AI scam threats from users” . not only this one we took as the reason for implement this system and continue our research.

Others are:

- Most of the systems they act as they can detect is this is the AI scams or not . but of the times they comes as the false postive results.
- There are some highly accurate, effective tools that can detect, defense and give awareness to the users. But the reason is they are highly cost. so SME cannot bear these kind of cost as their investment.
- Most of the tools exist for separate tasks. Less number of tools do multitasking. If they do then they become highly cost or they have huge number of false postives.
- The current world mainly focuses on user awareness, but the reason is that some continue without practically. There are not any option user can explore and then give suitable awareness for the dynamically changing scams they face. Sometimes awareness can be unreliable.

System Benefits

- Mainly through our system we focus on multitasking. This means that through our system, it can detect, defense and also give the user awareness dynamically.
- We offer a lightweight system that can use SME and also individual users.
- More effective and user friendly for end user.
- Less false positives compared with other tools in real world
- Give users to the practial expereince and through out that user can gain complete knowledge of the scam protection and it’s environment.

System Components

Inside the system, there are 3 main components working. So they are,

1. Component 01 - A Lightweight Detect System for AI Driven scams

2. Component 02 - Human-Centred Defense and Awareness System for AI-driven scams.

3. Component 03 - Explainable AI-Based Steganographic Image Detection In Email Attachments.

Component Responsibilities

When we looks seperately each 3 components they are working like this.

1. Component 01 - A Lightweight Detect System for AI Driven scams

This is the foundation and first component that starts the system. That is the email after it arrives in the inbox (general email arrival mechanism), after that the user selects “Analyze this email” through an add-on or extension. next that the component 01 analyze if the email of actually an AI-generated scam or not using it’s methods (component 01’s detection methods. Such as analyze uncertain signals and etc)

2. Component 03 - Explainable AI-Based Steganographic Image Detection In Email Attachments.

This work as the optional component if there is a image attached with the email it auomatically analyze image attachedment in this component and view is that image actually affect/infect by the stegnogrpahy or not.

3. Component 02 - Human-Centred Defense and Awareness System for AI Driven scams.

This is the core of the overall system. That one working on the outputs of component 01 and component 03. Mainly what the do is if selected email identified as the AI scam based on it risk

score it decide what kind of safe action is appropraite for selected one. Like what kind of safe action must take. Like still allow the user to perform his action (show the result and let the user continue normally.) , allow (show the result and let the user continue normally.) the user to perform his action within the restrciton area (display inert text inside the add-on without active links or attachment controls) , or quarntine that affected/ infected email (move the email out of the inbox into a designated folder, with a review/release option) , or fully block (blocked and remove form entire Thunderbird email client) . After that then give user to proper and clear understanding with user awareness dynamically. Additionally, it shows the user's vulnerability profile, though the user can see what the recent activities are and also the history that the user performs throughout the overall system.

Integrated System Workflow

Overall system establlished as the web extension. It mean product is web extension. So this web extension currenlty works only on thunderbird email client. So user can install this web extension through our website (external part). So when user install it user manually have to config it on the thunderbird email client as the add on extension. So it may ask for a few permissions from the user before setup and start to establsihed it’s configurations and backend process. There are, “Enable protective actions (optional) and Analyze selected content”. So under that if user want to know why we asked these type of permissions from users then we add “Learn more” option to trigger it shows why we need to these kind of permissions from the user. So after that user allows all then our web extension established it’s setup configurations.

So now the our system woking start. So when user go through the inbox if he selected an email then he can click or select the “Analyze this email” option, which shows after the finshed setup of system configurations. If user click that option then the email capture by our system and start to working on selected email. So component 01 insert “.eml” file to its environment. Simultaniously component 03 also start to analyze the email and find is there any “.png” image attachments in the email. From now onwards I tell first how component 01 is working though the selected email. After that I explain how the component 03 working on the system. After component 01 insert it’s to the whatever arrived (.eml, raw file, JSON, or text) is turned into one standard internal objects like subject, body, sender, headers, links, and attachments. Then it extract the features that need

to clearly identified the excatly is this one really AI genetated scam or not. So these are the filtering mechnaisms use for that. they are,

If selected, email must passing all filters which are bellow mentioned in the table, to say accurately is the email originaly AI scam, then it must face these. They are,

Detection Checks

Check	What it checks
SPF authentication	Whether the sending server is authorized to send email for the envelope-sender domain.
DKIM verification	Whether the email has a valid domain signature and the signed content remains intact.
DMARC alignment	Whether a passing SPF or DKIM identity aligns with the visible From domain.
Malicious sender-domain check	Whether the sender's domain appears in the locally cached threat blocklists.
Brand impersonation check	Whether the sender domain imitates a trusted organization through misspellings or lookalike characters.
Reply-To mismatch	Whether replies are directed to an address different from the sender, which may warrant investigation.
DNS/mail-record check - optional	Whether the sender domain has relevant DNS/mail records.
Social-engineering language	Whether the subject or body contains urgency, threats, secrecy, fake prizes, payment demands, or remote-access installation requests.
Malicious URL check	Whether email links match known-malicious URLs or domains in the cached feeds.
Suspicious URL structure	Whether links use shorteners, raw IP addresses, or disguised destinations.
Link-text mismatch	Whether the displayed destination differs from the actual link destination.
Attachment-risk check	Whether attachments have potentially dangerous types, macro-enabled formats, double extensions, or archive formats. This does not itself confirm malware.
DistilBERT scam classification	Whether the email text resembles scam patterns learned by the fine-tuned model.
Text predictability	Uses distilgpt2 to assess how predictable the wording is, as a supporting AI-writing signal.
Sentence-length variation	Measures variation in sentence lengths as a supporting writing-style feature.
Vocabulary repetition	Measures repeated words or phrases as a supporting AI- writing feature.
AI-writing classification	Uses the small classifier's trained features to estimate whether the text is AI-written.
Minimum-text-length check	Determines whether the body contains enough words to run the AI-writing assessment.

Using together, they can support a "Suspected AI-assisted scam".

so here there is some conditionals,

There are short emails, or ones already judged legitimate, that skip above all these steps.

So after all this, generate the risk score. Here is the mechanism

Scam Risk Calculation

$$z = b + w_m p_m + \sum_{i=1}^{n} w_i x_i$$

$$p_{\text{combined}} = \frac{1}{1 + e^{-z}}$$

Symbol definition.

p_m - DistilBERT's scam probability (assess scam-related risk – DistilBERT model)

x_i - A scam-related feature: malicious URL match, impersonation, credential request, authentication result, etc. (assess scam-related risk – without DistilBERT model)

w_m, w_i - Weights learned from labelled training data, not manually invented

b - Learned baseline value

w_m, w_i , b = numbers learned when training the combination model using those inputs and scam/legitimate labels.

$$\text{Scam Risk score} = 100 \times \text{Calibrate}(p_{\text{combined}})$$

When the risk score has not include the follwing lists,

- AI-writing probability.
- Minimum text length.
- Whether the AI detector ran.
- C3's steganography score; send that separately as image evidence. After the risk score is calucluated then the particular email's (selected email's) ,
- Generate scam risk score
- Supporting evidence (explanabile/ resonable evidence)
- Analysis status and missing checks (indicators)
- AI authorship assessment (possible AI involment) Pass component 2 as the ouputs. Now the email detection system process is over. Previously mentioned c3 component is another independent system. What it do is component 03 start to analyze the email (.eml or whatever the arrives raw, text or json) and find is there any ".png" image attachments in it. Analyse each .png images by the Flask backend sends the image through the trained AI model to predict whether it is clean or stego. After that it predict that image has stegnogrphy next explain the prediction Grad-CAM generates a heatmap showing regions that influenced the model's decision. Finally C3 produce C2 these kind of outputs. They are,

- Prediction - Whether the AI classifies the image as Clean or Stego
- Clean score - The model's score for the clean class.
- Stego score - The model's score for the stego class
- Grad-CAM heatmap - A visual explanation of image regions that influenced the prediction
- Image information - image details. Date and name After that comes outputs (c1 and c3 outputs) as the inputs of the component 2 , which is “Human Centered Defense and Awareness System” is start. Here all the putputs c2 use for two different stages. From c1 outputs,
- Generate scam risk score - defense engine
- Supporting evidence (explanabile/ resonable evidence) - awareness engine
- Analysis status and missing checks (indicators) - awareness engine
- AI authorship assessment (possible AI involment) - awareness engine From c3 outputs,
- Prediction (Whether the AI classifies the image as Clean or Stego) - defense engine
- Stego score (The model's score for the stego class) - defense engine
- Clean score (The model's score for the clean class.) - awareness engine
- Grad-CAM heatmap - A visual explanation of image regions that influenced the prediction - awareness engine
- Image information - image details. Date and name - dashbord. (may be awaress engine need)

Based on the above outputs. (for the defense mechanism to take the desion is depend on the generated scam risk score. (component 2’s input) decide which kind of defese mechanism is applicable for the selected email. That is if the calulation risk score become ,

- 0 - 10 (Low) - allows user to perform their action. It mean consider it no AI scams or if the selected email is AI scam but it may be include few word text only or very short (only text) email (may be AI scam email identified by component 1).
- 11 - 39 (Medium) - allows user to perform their actions. Withing the restriction areas. Means, only users can read the selected email. Can not click links, download or view the attachments, coping or paste and anything.
- 40 - 69 (High) - quarintine the selected email. Like it move the junk folder or another safe area , that user ralty access that folder.
- 70 - 100 (Critcal) - blocked the selected email and remove it from the email client (inbox).

So here mentioned how the system continues.

1. Picture an inbox. A new email lands. Thunderbird hands it to the system.
2. Two things happen at the same time, completely separately:
3. C1 reads the words in the email. It is checking: does this sound like a scam?

4. C3 checks whether the email has an image attached. If it does, C3 looks closely at that image. It is checking: is something hidden inside this picture?
5. C1 does not wait for C3. C3 does not wait for C1. They work independently, and each one only speaks up if it actually finds something.

Case 1 - A normal, safe email

1. Say the email is just a real message from a colleague. No scam language, no hidden image.
2. C1 reads it, finds nothing alarming, and stays quiet. C3 either finds no image, or finds an image with nothing hidden in it, and also stays quiet.
3. Because nothing was flagged, C2 has nothing to act on. The email goes straight to the inbox. A small, quiet record is still kept, so later the user can see the system did check this email and found it safe - but the user is never bothered with it.

Case 2 - A scam email, text only

1. Now say the email is a phishing attempt - it asks the user to click a link and enter their password.
2. C1 reads the text and becomes suspicious. It produces four things:
3. A Score from 0 to 100 - how confident C1 is that this is a scam. Say it comes out to 55.
4. Supporting Evidence - for example, the link goes to a lookalike domain, and the email asks for a password.
5. Its own Reliability - did every part of C1's analysis actually finish properly, or did something get skipped? Say everything ran fine, so reliability is high.
6. Whether the writing itself looks AI-generated, from its own separate AI-detector - an AI Authorship signal. Say the writing does show signs of being AI-written.
7. All four of these go to C2. Here is the important part: C2's Defense Engine only looks at one of them - the Score. It sees 55, which falls in the High band (40-69), so its decision is immediate and simple: quarantine the email - move it out of the inbox into a safe folder the user rarely opens.
8. The other three - Evidence, Reliability, AI Authorship - never touched that decision. They go somewhere else: the Awareness Engine, the part of C2 that explains things to the user. It takes those three and writes something the user can actually understand: "This email was quarantined because it scored 55 out of 100 for scam risk. It links to a lookalike domain and asks for your password. The detection ran completely, so this result can be trusted, and the writing style matches AI-generated text - all of which point the same way."
9. So: one number decided the action. Three other things explained why.

Case 3 - A hidden image; text looks fine

1. Now imagine a different email. The written message looks completely ordinary - nothing C1 flags. But it has an image attached and hidden inside that image is secret data.
2. C1 stays quiet - nothing in the text looks wrong.
3. C3 examines the image and produces four things: a Prediction (Clean or Stego - here, Stego: something is hidden), a Stego score (how confident C3 is in that call - say 80), a Clean score (its confidence in the opposite answer), and a Grad-CAM heatmap (a picture highlighting exactly which part of the image looks suspicious).
4. Just like before, C2's Defense Engine only uses two of these - Prediction and Stego score - and maps them straight to a severity level. A Stego verdict at 80% confidence lands in the Critical band, so the email is blocked and permanently removed - no undo.
5. The Clean score and the heatmap never reach the Defense Engine. They go to the Awareness Engine instead, which uses the heatmap to show the user exactly which part of the image triggered the alert - real, visual proof, not just a claim.

Case 4 - Both fire at once

1. Now the hardest case: the text looks somewhat suspicious to C1, and the image also looks suspicious to C3 - at the same time, completely independently of each other.
2. Say C1's text analysis comes back Medium. Say C3's image analysis comes back High.
3. C2 does not just pick the bigger of the two and move on. It looks both severities up in a fixed table. Medium and High together land on High. The email is quarantined, and the user sees one explanation covering both reasons - the wording in the message, and the finding in the image.
4. There is one special case in that table worth telling as its own small story: if C1 says High and C3 also, independently, says High, C2 does not just call it High. Two separate systems, looking at two completely separate things - the words and the image - both independently raising the same serious alarm is treated as more dangerous than either one alone. So that one combination escalates a step further, to Critical, and the email is blocked for good.

Severity Arbitration Matrix

	C3 - Low	C3 - Medium	C3 - High	C3 - Critical
C1 - Low	Low	Medium	High	Critical
C1 - Medium	Medium	Medium	High	Critical
C1 - High	High	High	Critical	Critical
C1 - Critical	Critical	Critical	Critical	Critical

Awareness Engine

Once the Defense Engine has already picked the action, the Awareness Engine still has one more job. That is choosing exactly which explanation to show. It keeps a set of pre-written, plain-English explanation templates - one for each kind of flagged email. A small, lightweight classifier helps pick the right template, but it is never allowed to write its own sentences, and it is never trusted blindly: whatever it picks has to pass a check against the actual evidence first. If that check fails, the system falls back to a simple, deterministic rule instead of guessing. This way, nothing the user reads is ever made up - it is always one of a known, checked set of explanations.

Dashboard

Everything that happened - the action taken, the explanation, the evidence - ends up in one place the user can actually look at the dashboard. The very first thing it shows, before any numbers or details, is one simple answer to the question "am I okay right now?" Underneath that sits a feed of only the emails that were actually flagged - a totally clean email doesn't clutter this feed, it just quietly adds to a small "scanned" counter at the bottom. Nothing on the dashboard is ever just a bare number - every score, every label, has its reasoning one click away, the same rule that runs through everything else in this system.

Vulnerability Profiler

There's one more part of the story that isn't about any single email - it's about the user, over time. Every time the user reacts to a warning - ignoring it, heeding it, clicking through anyway - that gets quietly recorded. The Vulnerability Profiler looks at this history and works out, using a plain, documented formula - never a hidden model - whether the user is actually getting safer or not. It splits their history into an earlier half and a more recent half, compares how safely they acted in each, and settles on one of seven honest, plain-English labels - things like "Improving," "Needs Support," or "Declining" - each one coming with a one-line explanation of exactly how it was worked out. This is what turns a pile of individual email decisions into one running picture of how well the user is actually doing.

Selection of Thunderbird

- Becasuse thunderbird email client is an open-source email client. So anyone can freely use it.
- So most of the AI scams can come through this one. Because anyone can do configurations on it.

Limitations

- This current system is only working for the Thunderbird email client.
- Detection and defense and awareness work only on images, and text based. Not the voices and videos.
- Stegnogrphy image detection is perform LSB (Least Significant Bit) detection method and only check “.png” images.